

Warsaw, April 30, 2024

Decision

DKN.5131.58.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7(1) and Articles 60, 101, 101a(2), and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57(1)(a) and (h), Article 58(2)(i), Article 83(1) and (2), Article 83(4)(a) in connection with Article 33(1) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of May 4, 2016, p. 1, OJ EU L 127 of May 23, 2018, p. 2, and OJ EU L 74 of March 4, 2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting administrative proceedings regarding the violation of personal data protection regulations by the Association "Marathon" based in Gorlice at 10 Biecka Street, the President of the Personal Data Protection Office, finding a violation by the Association "Marathon", based in Gorlice at 10 Biecka Street, of Article 33(1) of Regulation 2016/679, consisting of the failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach, imposes on

the Association "Marathon" based in Gorlice at 10 Biecka Street, an administrative fine in the amount of 916.71 PLN (in words: nine hundred sixteen zlotys and seventy-one groszy).

Justification

The Personal Data Protection Office, hereinafter also referred to as "UODO", received a letter dated January 24, 2022, informing about a personal data breach by the Association "Marathon" based in Gorlice at 10 Biecka Street (hereinafter: "the Association" or "the Administrator"). The sender of the letter was a family member of individuals whose personal data were involved in this breach.

The personal data breach consisted of the disclosure on the Association's profile on the Z. portal of a list of participants in amateur sports competitions (which took place as part of the events "R." and "X.") containing excessive personal data of individuals participating in these competitions. The excessive personal data were accessible to individuals who downloaded the aforementioned list from the Association's profile on the Z. portal and then opened the file containing it in the M. program and edited the list in question. The list of competition participants, which was visible on the Association's profile on the Z. portal (intentionally placed there), contained the following data: first name, last name, gender, club, and locality. However, after downloading and editing in the M. program, the list of participants included the following data: first name, last name, gender, club, locality, email address, and date of birth. It should be emphasized that the Association had the right to publish the personal data of competition participants; however, the scope of the disclosed personal data should have been adequate to the purpose of such publication. In the explanations provided to the supervisory authority, the Association itself admitted that due to a volunteer's mistake, personal data of competition participants were disclosed in an excessive scope.

In connection with the above, on March 23, 2022, the President of the Personal Data Protection Office, hereinafter also referred to as "the President of UODO", based on Article 58(1)(a) and (e) of Regulation 2016/679, requested the Association to submit, within 7 days from the date of delivery of the letter, explanations as to whether an analysis regarding the risk of infringement of the rights or freedoms of natural persons necessary to assess whether there was a personal data breach requiring notification of the President of the Personal Data Protection Office and the individuals affected by the breach had been conducted in relation to the aforementioned incident. The Association did not receive the correspondence in time and did not provide explanations to the authority. Consequently, the President of UODO, by letter dated May 23, 2022, again requested the Association to submit explanations in the aforementioned regard.

In response to the above, the Association, by letter dated June 30, 2022, indicated that the start list of competition participants, which was posted on the Association's profile on the Z. portal, did not contain

personal data of individuals participating in the competition regarding their email addresses and dates of birth. Furthermore, the explanations indicated that after receiving the President of UODO's request for explanations, the Association removed the aforementioned list from its profile on the Z. portal. The Association pointed out that "(...) the start list was prepared by a volunteer, as the Association (...) does not have the means or personal resources to outsource such tasks to external entities (...)". The issue of disclosing excessive personal data was explained by the Association as follows: "(...) As can be seen from the information sent to us, obtaining additional information from the posted start list required additional efforts by a third party, which we did not foresee as the organizers of amateur competitions, nor did the volunteer preparing the list of participants foresee this (...)". At the same time, the Association indicated that participants voluntarily consented to the processing of their personal data.

(to the explanations, the Association attached the competition regulations, which among other things regulates the issue of processing personal data). The Association explained that the personal data of participants, which it had obtained, were processed solely for the purposes of the competitions – to which each participant had to give consent (in accordance with the provision of point (...) of the competition regulations). Furthermore, it was indicated that "(...) email addresses were provided by the competitors for the purpose of efficient communication with the participants. On the other hand, dates of birth are necessary for determining the age groups in which individual competitors participated (...)".

Due to the failure to provide the President of the Personal Data Protection Office (UODO) with a comprehensive response to the request dated May 23, 2022, the supervisory authority, by letter dated August 5, 2022, again called on the Association to indicate whether an analysis had been conducted regarding the risk of violation of the rights or freedoms of individuals necessary to assess whether there had been a breach of data protection that would require notifying the President of UODO and the individuals affected by the breach.

In the absence of a response to the aforementioned request, the President of UODO – again by letter dated October 21, 2022 – called on the Association to provide explanations. In a letter dated November 2, 2022, the Association once again did not provide a precise response to the President of UODO's request, only indicating that "(...) it is a social organization operating on a voluntary basis and has been continuously organizing a series of recreational and sports events under the common name aimed at individuals from preschool age to unlimited age since 2003 (...) In 2021, we organized as an Association (...) running competitions [B.] and roller skating competitions, and in cooperation with {another entity} cycling competitions (...) For all the aforementioned competitions, regulations were prepared defining the rules for conducting the competitions, including in the final provisions the statement: Participants registering for the competition consent to the processing of their personal data for the purposes of the competitions and consent to the dissemination of their image in film and photographic materials from the competitions (...). In the registration, those willing to participate in the event provided their data, including an email address necessary for correspondence with the competitor and their date of birth, which was in turn necessary for assigning each competitor to an age category in accordance with the competition regulations. On the day of the competition, directly at the competition office, all participants signed statements regarding their participation in the competition and regarding consent to the participation rules specified in the competition regulations and signed the start list. (...) I would like to point out that the start list made available to the competitors on the day of the competition contained only the first name, last name, and the name of the club represented by the given competitor. At no stage of the competition was information with the personal data of the competitors made available. On the website and on the Z. {profile on the social media portal Z.} of the association, a start list was posted containing only the first name and last name of the competitor, information about which club each competitor represents, and the town from which each competitor comes. After receiving a notification from the Personal Data Protection Office (...) that one of the participants in the competition copied the data presented on the Z. {profile on the social media portal Z.} of the Association without the consent and knowledge of the organizer, it was immediately removed. I would like to emphasize that the Association (...) did not authorize anyone outside the group of organizers to, as stated in the letter from UODO in Warsaw dated May 23, 2022, improve the

appearance and sort the competitors by distance and gender. Considering that there were just over 100 participants in the competition over two distances (...), no additional actions on the start list were either necessary or required. We emphasize that at the stage of organizing the competition and after its conclusion, we did not find that the personal data of individuals voluntarily participating in the amateur roller skating competitions in G. were unlawfully made available to anyone outside the organizer. The information that reached UODO in Warsaw was not reported to the organizer by anyone either before or after. However, after receiving the letter from UODO dated May 23 {2022}, the start list was immediately removed to prevent any further interference or hacking into the organizer's website or into the start list and the data of the individuals participating in the competition. We inform you that the Association (...) operating solely on the principles of social work and volunteering does not have legal services nor does it have financial resources allowing it to commission legal services to an external entity. In connection with the incident, we turned to the District Office in G., as the authority supervising the activities of Associations operating in the G. District. The G. District Office, citing the Act on Associations, refused assistance and consultation in this matter, responding: According to Article 25 of the Act of April 7, 1989 - Law on Associations, the supervisory authority supervises the activities of associations solely in terms of compliance of their activities with the provisions of law and the provisions of the statute (...)."

In the absence of a report of a breach of personal data to the supervisory authority, on December 1, 2022, the President of UODO initiated administrative proceedings against the Association for the violation by the Administrator of Article 33(1) of Regulation 2016/679. Furthermore, the President of UODO requested the Association to indicate the exact number of individuals whose excessive personal data were made available on the Association's profile on the Z. portal in connection with the organized sports competitions mentioned above.

The letter mentioned above was returned to the Personal Data Protection Office. This letter was returned by the operator.

postal with the annotation on the envelope "Return, not picked up in time," stamped with seal G. 1 and dated December 21, 2022, after two notifications on December 6 and December 14, 2022. According to Article 45 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended; hereinafter referred to as: Kpa), letters are delivered to organizational units and social organizations at their registered office to the hands of persons authorized to receive letters. The provision of Article 44 applies accordingly. Pursuant to the content of Article 44 § 1 of the Act of June 14, 1960, Kpa, in the event of inability to deliver a letter in the manner indicated in Articles 42 and 43 Kpa, the postal operator, as understood by the Act of November 23, 2012 – Postal Law, keeps the letter for a period of fourteen days at its postal facility – in the case of delivery by post (point 1), the letter is deposited for a period of fourteen days at the office of the relevant municipality (city) – in the case of delivery by an employee of the municipality (city) or an authorized person or authority (point 2). A notification of the deposit of the letter along with information about the possibility of its collection within seven days, counting from the day of leaving the notification in the place specified in § 1, is placed in the outgoing mailbox or, when this is not possible, on the door of the addressee's apartment, office, or other premises where the addressee conducts their professional activities, or in a visible place at the entrance to the addressee's property (Article 44 § 2 Kpa). In the event of non-collection of the shipment within the time frame mentioned in § 2, a repeated notification of the possibility of collecting the shipment is left within a period not exceeding fourteen days from the date of the first notification (Article 44 § 3 Kpa). Delivery is considered completed upon the expiration of the last day of the period referred to in § 1, and the letter is left in the case files (Article 44 § 4 Kpa).

In light of the above provisions, it should be accepted that the shipment (containing a notification of the initiation of administrative proceedings) addressed to the Association was duly delivered to the addressee upon the expiration of December 20, 2022. By a letter dated November 22, 2023 (received by the Association on December 8, 2023), the supervisory authority again requested the Association to specify the exact number of individuals whose personal data were made available on the Association's profile on the Z. portal in the form of a list of participants in the sports events that took place as part of

the "R." and "X." events. Furthermore, in the aforementioned letter, the President of the UODO requested the Administrator to present the annual financial report of the Association for the year 2022. The Administrator did not respond to the aforementioned letter.

The supervisory authority assessed the evidence material in terms of examining its credibility and evidentiary value. The President of the UODO deemed the majority of the evidence material credible. The only doubt regarding the credibility of the collected evidence may arise from the fact that the exact number of individuals affected by the violation was not established. The supervisory authority made multiple attempts to determine this number. From the letter of the person reporting the violation of personal data protection, it appears that the violation may have concerned 140 or 180 individuals, while the explanations provided by the Administrator indicate that the violation may have involved just over 100 individuals. In the opinion of the supervisory authority, the discrepancy between these two numbers does not hinder the determination of the scale of the violation of personal data protection, and consequently does not have a significant impact on the resolution contained in this decision.

After reviewing all the evidence collected in the case, the President of the Office for Personal Data Protection considered the following. In assessing whether a violation of personal data protection results in a risk of infringement of the rights or freedoms of natural persons, one must take into account, among other things, the content of recitals 75 and 85 of Regulation 2016/679. Moreover, the European Data Protection Board (hereinafter referred to as: EROD), in Guidelines 9/2022[1], indicated that the administrator should assess the specific circumstances of the violation, the data concerned by the violation, and the potential level of impact on individuals, as well as the likelihood of the realization of this risk.

The aforementioned guidelines also indicate that when assessing the risk that may arise from the violation, the administrator should consider the combination of the severity of the potential impact on the rights and freedoms of individuals and the likelihood of their occurrence. Of course, where the consequences of the violation are more serious, the risk is greater, and similarly, where the likelihood of their occurrence is higher, the risk is also elevated.

According to Article 4 point 12 of Regulation 2016/679, "personal data breach" means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

Article 33 paragraphs 1 and 3 of Regulation 2016/679 states that in the case of a personal data breach, the data controller shall without undue delay – where feasible, not later than 72 hours after becoming aware of the breach – notify the supervisory authority competent under Article 55, unless the breach is unlikely to result in a risk to the rights or freedoms of natural persons. A notification submitted to the supervisory authority after the 72-hour period must include an explanation of the reasons for the delay. The notification referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of individuals concerned, as well as the categories and approximate number of personal data records concerned by the breach; b) contain the name and contact details of the data protection officer or...

the President of the Personal Data Protection Office (UODO) to provide information regarding the incident, the Association failed to adequately respond to these requests. This lack of cooperation further exacerbates the situation, as it prevents the supervisory authority from fully assessing the implications of the data breach and taking appropriate measures to mitigate its effects.

In light of the above, it is clear that the Association did not fulfill its obligations under the General Data Protection Regulation (GDPR), specifically in relation to the principles of data minimization and purpose limitation. The intentional disclosure of excessive personal data, including birth dates and email addresses, constitutes a serious violation of the rights of the individuals concerned.

Furthermore, the Association's actions demonstrate a disregard for the importance of safeguarding personal data and the potential risks associated with its unauthorized disclosure. The failure to implement adequate security measures to protect the data of over 100 individuals not only undermines the trust placed in the Association by its members but also poses a significant risk to the privacy and

security of those individuals.

In conclusion, the findings indicate a clear breach of data protection regulations, necessitating a thorough investigation and appropriate sanctions against the Association to ensure compliance with the GDPR and to protect the rights of the affected individuals. The supervisory authority must take decisive action to address this violation and prevent similar occurrences in the future.

UODO, the Association did not respond to the question of whether an analysis was conducted regarding the risk of violation of the rights or freedoms of natural persons necessary to assess whether there was a breach of data protection resulting in the obligation to notify the President of UODO and the individuals affected by the breach. However, the evidence gathered in this case indicates that the breach of personal data (data confidentiality) that occurred in this case results in a risk of violation of the rights or freedoms of natural persons.

Typically, the potential impact of a breach increases with the number of individuals affected. However, depending on the nature of the personal data and the context in which it was disclosed, a breach may have serious consequences even for one individual. In this case, it is crucial to analyze the likelihood of consequences for the individuals affected by the breach, as well as how severe those consequences will be.

There is no doubt that in the case under discussion, the breach affects many individuals, which significantly raises the gravity of the breach and the likelihood of the risks associated with the breach of personal data materializing. Notably, for such a risk assessment, the ease of identifying the individuals whose data was compromised based on the disclosed data is significant—the fact that, as a result of the breach of personal data, there was no disclosure of, for example, the PESEL identification numbers of the affected individuals does not mean that these individuals cannot be identified. Consequently, this means that there is a risk of violation of the rights or freedoms of the individuals affected by the breach, which in turn results in the obligation for the Association, as the administrator of this data, to report the breach of personal data to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679.

In this case, as already mentioned, there was a disclosure of personal data of over 100 individuals, including: first name, last name, gender, club, locality, email address, date of birth—of which the excessive scope of personal data includes the information about the email address and date of birth (the remaining data was disclosed intentionally). The disclosure of such data is not, in itself, associated with a high risk of violation of the rights or freedoms of natural persons (and consequently, the Association was not obliged to notify the individuals whose data was affected about the breach, in accordance with Article 34 of Regulation 2016/679); nevertheless, this does not equate to a lack of risk as such—hence the necessity to notify the President of UODO about the breach of personal data.

The possible risk associated with the event in question is, in particular, the loss of control over their data by the individuals whose data is concerned. For example, personal data regarding the email address may be used to establish (unwanted by the individuals concerned) contacts via email—also those during which attempts will be made to obtain additional data from these individuals. Finally, using this data, accounts may be created on various social media and internet portals, which may negatively impact the perception of these individuals in their professional or family environment and may even lead to their discrimination.

Thus, this means that in the case of the breach of personal data in question, there is a risk of violation of the rights or freedoms of natural persons. It is particularly important to emphasize that the possible consequences of the event in question do not have to materialize—Article 33(1) of Regulation 2016/679 states that the mere occurrence of a breach of personal data, which is associated with a risk of violation of the rights or freedoms of natural persons, implies the obligation to report the breach to the appropriate supervisory authority. This position has been confirmed by the Provincial Administrative Court in Warsaw in its judgment of September 22, 2021, in case file II SA/Wa 791/21: "It should be emphasized that the possible consequences of the event in question do not have to

materialize. Article 33(1) of Regulation 2016/679 states that the mere occurrence of a breach of personal data, which is associated with a risk of violation of the rights or freedoms of natural persons, implies the obligation to report the breach to the appropriate supervisory authority, unless it is unlikely that the breach will result in a risk of violation of the rights or freedoms of natural persons" (the Court similarly ruled in its judgment of July 1, 2022, in case file II SA/Wa 4143/21 and in judgments of August 31, 2022, case file II SA/Wa 2993/21, November 15, 2022, case file II SA/Wa 546/22, and April 26, 2023, case file II SA/Wa 1272/22).

Moreover, the Provincial Administrative Court in Warsaw, in its judgment of April 26, 2023 (case file II SA/Wa 1272/22), indicated that "(...) in the course of assessing whether there are risks of violation of the rights or freedoms of individuals, the administrator should take into account all possible damages, as well as harms that may result from a given event for natural persons [see: S. Jandt [in:] DS.-GVO..., ed. J. Kühling, B. Buchner, p. 617; Y. Reif [in:] DS.-GVO..., ed. P. Gola, p. 496]. These may particularly consist of the loss of control over one's personal data, negative reputational consequences, the possibility of another person entering into contracts using the personal data of another individual, financial losses, or finally negative social perception, which may be a consequence of the public disclosure of certain personal data. The occurrence of risk does not require that there ultimately be a manifestation of the breach."

damaged or harm resulting from a given violation of personal data protection [yes: *ibid.*, p. 616] (...)"

Without affecting the above assessment of the risk of violation of the rights or freedoms of individuals related to the incident that occurred, it remains a fact that – as explained by the Association – "(...) after receiving the letter from the UODO dated May 23, 2022, the start list was immediately removed to prevent any further intrusions or hacks into the organizer's website or into the start list and the data of the participants in the competition (...)" Even despite the removal of the list of competition participants (which occurred after May 23, 2022), there is no certainty that before the removal of this list (the President of the UODO received information about the incident in a letter dated January 24, 2022) other individuals did not download the list in question and did not edit it, and consequently did not familiarize themselves with the personal data of the participants in the competitions organized by the Association to the extent that was originally hidden. It should be emphasized that the state of improper disclosure of personal data persisted for several months and took place in the online space (social media portal Z.), and consequently, the potential number of unauthorized recipients of the personal data of the participants in the sports competitions organized by the Association is practically impossible to estimate.

The mere execution of the actions indicated by the Association does not provide any guarantees that the personal data of the participants in the sports competitions have been removed from all possible data carriers and that they will not be used in the future by unauthorized persons.

It should also be emphasized that the Association, allowing the possibility of publishing the start lists of participants in sports competitions on the Internet, should be aware of the risks associated, for example, with the possibility of editing such a list by individuals possessing the skills to extract data that – before their publication on the Internet – were hidden. The existence of these risks, in the absence of actions by the data administrator aimed at minimizing them through the implementation of appropriate organizational and technical measures, directly leads to the emergence of the risk of violation of the rights or freedoms of individuals whose data is made available in this manner. Therefore, the explanations provided by the Association, which indicated that "(...) the start list was prepared by a volunteer, as the Association (...) does not have the means or personal resources to commission such tasks to external entities (...)" and "(...) the Association (...) did not authorize anyone outside the organizers to, as stated in the letter from the UODO in Warsaw dated May 23, 2022, improve the insight and categorize the competitors by distance and gender (...)" do not merit consideration. As evidenced by the evidence material, the Association did not implement any effective organizational and technical measures that would limit the risk of unjustified disclosure of the personal data of the participants in the sports competitions.

Considering that the Association pointed out its limited organizational capabilities – due to the fact that

the tasks it performs are carried out by volunteers and the competitions organized by this entity are of an amateur nature – it should be emphasized that these circumstances are irrelevant from the perspective of the obligations of the Association as a data administrator.

It should also be noted that despite multiple calls from the President of the UODO, the Association did not provide exhaustive explanations to the supervisory authority in the requested scope – i.e., it did not indicate whether an analysis was conducted regarding the risk of violation of the rights or freedoms of individuals necessary to assess whether there was a violation of data protection resulting in the need to notify the supervisory authority and the individuals concerned about the violation. The above indicates the Association's disregard for the obligations imposed on data administrators after the commencement of the application of the provisions of Regulation 2016/679. This is unacceptable in a situation where the nature of the Association's activities inherently involves the necessity of processing personal data of many individuals. It is impossible to accept that the organization of sports competitions (even those of an amateur nature) is not associated with the necessity of processing the personal data of the participants in such competitions, e.g., for the purposes of documenting results (e.g., preparing participant lists: start lists, result lists) and with the prior assumption that the course and results of the competitions will not only be documented but also published. The Association itself acknowledged this, indicating that "(...) on the day of the competition, directly at the competition office, all participants signed statements regarding their participation in the competition and regarding consent to the participation rules specified in the competition regulations and signed the start list (...)" and referring to the provisions of the regulations, according to which: "(...) The applicant for participation in the competition consents to the processing of their personal data for the needs of the competition and consents to the dissemination of their image in film and photographic materials from the competition (...)". Therefore, the Association should be aware of the obligations associated with this regulated by the provisions on personal data protection and its related responsibilities as a data administrator.

In a situation where, as a result of a violation of personal data protection, there is a risk of violation of the rights or freedoms of individuals (and as demonstrated above, such a risk occurred in the discussed case), the administrator is obliged to implement all appropriate technical and organizational measures to immediately identify the violation of personal data protection and quickly inform the supervisory authority. The administrator should fulfill the obligation in question as quickly as possible.

In Recital 85 of the preamble to Regulation 2016/679, it is explained: "In the absence of appropriate and timely action, a personal data breach may result in physical harm, material or non-material damage to individuals, such as loss of control over their personal data or restrictions on their rights, discrimination, identity theft or identity fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Therefore, as soon as a personal data breach is identified, the controller should notify the supervisory authority without undue delay, and where feasible, no later than 72 hours after becoming aware of the breach, unless the controller can demonstrate in accordance with the principle of accountability that the breach is unlikely to result in a risk to the rights or freedoms of natural persons. If notification cannot be made within 72 hours, the notification should be accompanied by an explanation of the reasons for the delay, and the information may be provided in phases, without further undue delay."

In Recital 75 of the preamble to Regulation 2016/679, it is indicated, among other things: "The risk of a breach of the rights or freedoms of individuals, with varying probabilities and severity of threats, may arise from the processing of personal data that could lead to physical harm or material or non-material damage, in particular: if the processing could result in discrimination, identity theft or identity fraud, financial loss, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social damage; if the individuals whose data are concerned may be deprived of their rights and freedoms or the ability to exercise control over their personal data (...)."

When applying the provisions of Regulation 2016/679, it should be noted that their purpose (expressed

in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of individuals in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the performance of obligations by controllers – not only in situations where there has been a breach of personal data protection but also when developing technical and organizational security measures to prevent such breaches – these values should be considered first and foremost.

Consequently, it should be stated that the failure of the Association to notify the supervisory authority of the personal data breach related to the described incident within the timeframe specified in Article 33(1) of Regulation 2016/679 constitutes a violation by the Association of this provision.

Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this Regulation, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of the Personal Data Protection Office, exercising the authority granted to him under the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Association.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the controller and the processor, referred to in Articles 8, 11, 25 - 39, and 42 and 43, are subject to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, whichever amount is higher.

In this case, the administrative fine imposed on the Association was for the violation of Article 33(1) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679.

In deciding to impose an administrative fine on the Association, the President of the Personal Data Protection Office – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case that necessitated the application of this type of sanction in the present case and that had an aggravating effect on the amount of the imposed fine:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In this case, a violation of Article 33(1) of Regulation 2016/679 was established (consisting of the failure to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than within 72 hours of becoming aware of the breach). This is related to an incident involving the disclosure on the Association's profile on the Z portal of a list of participants in amateur sports competitions containing excessive personal data of individuals participating in those competitions. The violation established in this case concerns over one hundred individuals and is associated with the risk of infringement of their rights or freedoms. The disclosure

excessive data in the scope including, among others, the email address of a participant in a sporting event may, for example, facilitate the acquisition of further data by unauthorized persons. Moreover, the personal data obtained in the aforementioned manner may serve, among other things, to conduct a phishing attack. It should be emphasized – as has already been detailed earlier – that the consequences of the event in question do not necessarily have to materialize. In light of the above, it should be pointed out that there is a likelihood that the discussed event may lead to material or non-material damages for the individuals whose data has been breached. The mere breach of the confidentiality of their data constitutes a non-material damage (harm) for them; individuals whose data has been unlawfully obtained may at least feel apprehensive about losing control over their personal data. As indicated by the District Court in Warsaw in the judgment of August 6, 2020, case reference XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that “[a]rt. 82 para. 1 of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a person whose data is concerned experiences as a result of a breach of this regulation, may in itself constitute a ‘non-material damage’ within the meaning of this

provision.”

The President of the UODO considers the long duration of the breach by the Association of Article 33 para. 1 of Regulation 2016/679 as an aggravating circumstance. It should be assumed that the aforementioned breach has lasted since the Association became aware of the occurrence of the personal data breach, i.e., since May 27, 2022 (the date of receipt of the letter informing the Association dated May 23, 2022) and continues to this day.

The breach of personal data protection regulations established in this case is serious and significant, as it is related to the fundamental obligation of the administrator, namely the obligation to notify the supervisory authority of a personal data breach in accordance with the provision specified in Article 33 para. 1 of Regulation 2016/679. In this case, the Association failed to fulfill this obligation. Considering the above, the President of the UODO deemed the condition specified in Article 83 para. 2 lit. a) of Regulation 2016/679 to be aggravating.

2. Intentional nature of the breach (Article 83 para. 2 lit. b of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by the EDPB on May 25, 2018), hereinafter WP253, intent “includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act.” The Association made a conscious decision not to notify the President of the UODO about the personal data breach. There is no doubt that the Association, processing personal data in connection with the organization of sporting events, is obliged to have knowledge in the field of personal data protection, including knowledge of the consequences of identifying a personal data breach that results in the risk of infringing the rights or freedoms of individuals. The administrator made the decision to refrain from notifying the supervisory authority of the breach, despite the fact that the President of the UODO initially informed the Administrator about the possibility of a personal data breach in the Association that could result in the risk of infringing the rights or freedoms of the individuals concerned, and subsequently initiated administrative proceedings regarding the breach of Article 33 para. 1 of Regulation 2016/679 and directed further correspondence indicating that it concerned the breach of the aforementioned provision of Regulation 2016/679. The initiation of this proceeding by the President of the UODO regarding the obligation to notify the supervisory authority of the personal data breach and the direction of further correspondence in this matter should have raised at least doubts for the Administrator regarding the correctness of the position he adopted.

3. Degree of cooperation with the supervisory authority to remedy the breach and mitigate its potential negative effects (Article 83 para. 2 lit. f of Regulation 2016/679). In this case, the President of the UODO found the cooperation from the Association to be unsatisfactory. This assessment is related to the Association's response to the letters from the President of the UODO indicating the possibility of a risk of infringing the rights or freedoms of the individuals concerned by the personal data breach. Despite the aforementioned correspondence, the Association did not undertake the expected, appropriate actions in light of the discussed provisions, i.e., it did not provide evidence confirming that it had conducted an analysis of the event in terms of the risk of infringing the rights or freedoms of individuals and consequently did not notify the President of the UODO of the personal data breach.

4. Other aggravating or mitigating factors (Article 83 para. 2 lit. k of Regulation 2016/679). First and foremost, it should be emphasized that the scope of this provision, which necessarily has an open character, should encompass all relevant considerations regarding the socio-economic context in which the Administrator operates. The President of the UODO, comprehensively examining the case, noted additional circumstances affecting the assessment of the breach and the amount of the imposed administrative monetary penalty. In the assessment of the supervisory authority, the Administrator, by not providing complete explanations, demonstrated a dismissive attitude towards the obligations imposed on him by Regulation 2016/679. In the discussed case, the failure to respond or providing responses...

mowa w art. 40 i 42 rozporządzenia 2016/679, w związku z czym ta okoliczność nie ma wpływu na wymiar orzeczonej administracyjnej kary pieniężnej.

7. Współpraca z organem nadzorczym (art. 83 ust. 2 lit. k rozporządzenia 2016/679). Stowarzyszenie współpracowało z Prezesem UODO w trakcie postępowania, co należy uznać za okoliczność łagodzącą, jednakże nie ma to wpływu na wymiar kary, biorąc pod uwagę charakter naruszenia.

8. Inne okoliczności dotyczące naruszenia (art. 83 ust. 2 lit. l rozporządzenia 2016/679). Prezes UODO nie stwierdził innych okoliczności, które mogłyby wpływać na wymiar kary, co oznacza, że wszystkie inne czynniki zostały już uwzględnione w powyższych punktach.

Podsumowując, Prezes UODO, biorąc pod uwagę wszystkie powyższe okoliczności, uznał, że nałożona administracyjna kara pieniężna jest adekwatna do stwierdzonego naruszenia przepisów rozporządzenia 2016/679 i ma na celu nie tylko ukaranie Administratora, ale również zniechęcenie do podobnych działań w przyszłości.

the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers and processors, as stated in the provisions of Regulation 2016/679. Therefore, the fact that they were not applied cannot be considered to the detriment of the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

7. Financial benefits gained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of the Personal Data Protection Office (UODO) did not find that the administrator gained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the administrator. The determination of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. However, the absence of such benefits for the administrator, as a natural state independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "gained" – those that occurred on the part of the entity committing the violation.

In the opinion of the President of UODO, the administrative fine imposed fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case. It should be emphasized that the fine will be effective if its imposition leads to the Association fulfilling its obligations regarding the protection of personal data in the future, particularly in terms of reporting personal data breaches to the President of UODO.

A data breach occurs both when the event happens as a result of intentional action and when it results from negligence – the fact that the breach occurred due to an error does not exempt the administrator from the obligations specified in Article 33(1) of Regulation 2016/679 – hence the application of an administrative fine in this case is justified.

Regarding the amount of the administrative fine imposed on the Association, it should be noted that the Administrator does not belong to the group of entities listed in Article 102(1) and (2) of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781; hereinafter: u.o.d.o.), and therefore, in this case, the limitations on the amount (respectively to 10,000 or 100,000 PLN) of the administrative fine do not apply. Consequently, pursuant to Article 101 of u.o.d.o., the administrative fine is imposed on the Association based on and under the conditions specified in Article 83 of Regulation 2016/679. However, considering that the Administrator is also not an entrepreneur, the determination of the amount of the imposed administrative fine did not occur by reference to the total annual global turnover from the previous financial year.

Despite the call from the President of UODO directed to the Administrator, the Association did not provide the annual financial report for the year 2022. Consequently, the President of UODO estimated the basis for calculating the administrative fine imposed on the Administrator, taking into account its

size and the specificity of the conducted activity, in accordance with Article 101a(2) of u.o.d.o. In determining the amount of the administrative fine, the supervisory authority also relied on the statement regarding the revenues obtained in 2021. According to the financial report, the revenues of the Association in 2021 amounted to (...) PLN.

According to the provisions of Article 103 of u.o.d.o., the equivalent of the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 is calculated in PLN according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

In the opinion of the President of UODO, the imposed fine in the amount of 916.71 PLN (in words: nine hundred sixteen zlotys and seventy-one groszy), which is equivalent to 210.00 EUR (average euro exchange rate from January 29, 2024 – 4.3653 PLN), meets the conditions referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data.

Regarding the amount of the administrative fine imposed, the President of UODO considered that it is sufficiently deterrent and proportional to the violations that occurred in this specific case. It is worth emphasizing that the amount of the imposed fine, i.e., 210.00 EUR, is only 0.0021% of the maximum amount of the fine that the President of UODO could impose on the Association for the violations identified in this case – applying, in accordance with Article 83(4) of Regulation 2016/679, the static maximum fine (i.e., 10,000,000 EUR).

In the opinion of the President of the Personal Data Protection Office, the administrative fine serves the function representative, as it will constitute a response to the violation by the Association of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of the Personal Data Protection Office, it will indicate both to the Association and to other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of a personal data breach.

In this factual and legal situation, the President of the Personal Data Protection Office has decided as stated in the ruling.

[1] Guidelines of the European Data Protection Board on reporting personal data breaches, version 2.0, hereinafter referred to as Guidelines 9/2022.

Print article

Metadata

Provider:

Department of Control and Violations

Created by:

Mirosław Wróblewski

2024-04-30

Entered by:

Wioletta Golańska

2024-05-15 13:15:19

Last modified by:

Edyta Madziar

2024-05-15 14:09:28